IDOR Security Testing

Educational Bug Bounty Series • Authorized Security Research Only

■ Insecure Direct Object Reference (IDOR) — Security Testing

Contributed by Cyber_Spy.404 | Educational Bug Bounty Series

Scope and ethics: *Use authorized targets, controlled test accounts, and synthetic records.*

■ Executive Summary

IDOR is an access-control flaw where an application exposes an object reference but fails to verify the caller's permission to use it. The supplied six-page *IDOR.pdf* introduces API identifiers, parameter pollution, JSON formats, and API-version differences.

■ Core Testing Methodology

1. Identify object identifiers in API paths, query strings, and request bodies.
2. Create synthetic objects owned by two controlled accounts.
3. Establish the expected access policy for each account.
4. Review extra object-reference fields and alternate request formats.
5. Check duplicate parameters and JSON structure handling in a lab.
6. Verify legacy routes and methods enforce the same authorization rules.
7. Review read and write actions separately.
8. Record sanitized evidence without accessing third-party data.

■ High-Value Bug Bounty Tips & Edge Cases

• Extra object-ID parameters can reveal weak authorization if the server trusts client selection.

• Duplicate keys can be interpreted inconsistently.

• Arrays and nested JSON objects should be schema-validated.

• Legacy API versions may enforce weaker controls.

• Numeric, UUID, encoded, or hashed IDs still require authorization.

• Publicly indexed URLs do not authorize access to private objects.

• Only the first two pages are clearly readable in the supplied preview; no claims are inferred from unseen content.

■■ Educational Checklists & Safe Examples

```
GET /api/v1/records/[OWN-TEST-RECORD-ID] HTTP/1.1
Host: example.com
Authorization: Bearer [CONTROLLED-TEST-TOKEN]
```

• [ ] Ownership is checked for every read/write.

• [ ] Malformed and duplicate parameters are handled safely.

• [ ] API versions and routes share consistent controls.

• [ ] IDs are never treated as permission grants.

■■ Mitigation & Remediation

Implement object-level authorization on every endpoint, scope data queries to the authenticated user, validate request schemas, reject ambiguous duplicate keys, and test access control across users, tenants, methods, and versions.

Source Notes

Based on the supplied six-page *IDOR.pdf*. Page 1 introduces IDOR and object parameters; page 2 covers JSON suffixes, older API versions, and array-form identifiers. The remaining pages are not sufficiently readable in the supplied preview to support further source-specific claims.

Educational use only. Disclose findings responsibly.

Educational use only. Test only systems you own or are explicitly authorized to assess. Confirm redistribution rights for source-derived material.